

Day 1

Rule Configuration: Building a Least-Privilege Firewall Policy

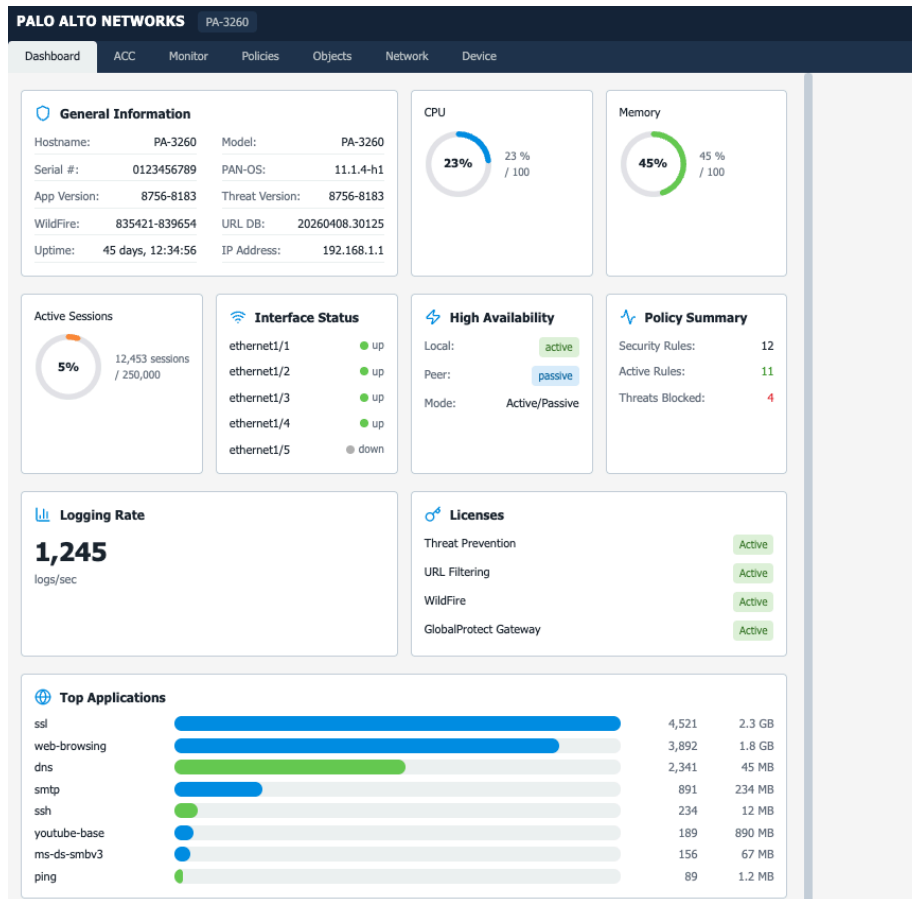
Day 1: 9/1/26

Jason Man

Part 1: Orient Yourself and Establish the "As-Found" Baseline

Step 1: Confirm basic zones exist

1. Open <https://paloalto-fw.networkershome.com> and confirm the simulator loads and shows the PAN-OS-style management console.



2. Go to Network > Zones. If two zones already exist named trust and untrust, you're set — skip to Step 2.

3. If no zones exist yet, create two: trust (representing the branch's internal network) and untrust (representing the internet). Leave the zone type at its default (Layer3, or the equivalent your simulator offers).

4. Go to Network > Interfaces (or the equivalent Network Interface / Virtual Router mapping screen) and confirm one interface is assigned to trust and one to untrust. If interfaces aren't pre-mapped, assign them now

Ethernet Interfaces						
Interface	Interface Type	Security Zone	IP Address	Virtual Router	Link State	Comment
ethernet1/1	Layer3	untrust	203.0.113.1/24	default	● up	Outside interface
ethernet1/2	Layer3	trust	192.168.1.1/24	default	● up	Inside interface
ethernet1/3	Layer3	dmz	10.0.1.1/24	default	● up	DMZ interface
ethernet1/4	Layer3	trust	192.168.2.1/24	default	● up	Secondary LAN
ethernet1/5	Layer3	None	N/A		● down	
ethernet1/6	Layer3	None	N/A		● down	
ethernet1/7	Layer3	None	N/A		● down	
ethernet1/8	Layer3	None	N/A		● down	

Trust and Untrust zones already exist with interfaces mapped.

Step 2: Recreate the legacy rule

- Go to Policies > Security and select Add (or the equivalent "new rule" control).
- Name the rule legacy-allow-all.
- Set Source Zone to trust and Destination Zone to untrust.
- Set Source Address, Destination Address, Application, and Service/URL Category all to any.
- Set the Action to Allow. Leave logging off and leave any Security Profile fields blank — this rule should be as bare and permissive as a rule can be.
- Save the rule. Take a screenshot of it. This is your "before" evidence.

Security Policy Rules													+ Add
#	Name	Source Zone	Source Addr	User	Dest Zone	Dest Addr	Application	Service	Action	Profile	Opt	Hits	
1	Allow DNS	trust	any	any	untrust	any	dns	application-default	allow	○	📄	15,420	🔗 📄 ⬆ ⬇ 🛑
2	Allow Web Browsing	trust	any	any	untrust	any	web-browsing, ssl	application-default	allow	○	📄	89,234	🔗 📄 ⬆ ⬇ 🛑
3	Allow Email	trust	any	any	untrust	any	smtp, imap, pop3	application-default	allow	○	📄	5,621	🔗 📄 ⬆ ⬇ 🛑
4	DMZ Web Servers	untrust	any	any	dmz	WebServer-1, WebServer-2	web-browsing, ssl	service-http, service-https	allow	○	📄	45,678	🔗 📄 ⬆ ⬇ 🛑
5	Trust to DMZ	trust	any	any	dmz	any	any	any	allow	○		12,340	🔗 📄 ⬆ ⬇ 🛑
6	Allow ICMP	trust	any	any	untrust	any	ping	application-default	allow	—		3,456	🔗 📄 ⬆ ⬇ 🛑
7	VPN Access	untrust	VPN-Pool	any	trust	any	any	any	allow	○	📄	7,890	🔗 📄 ⬆ ⬇ 🛑
8	Block Social Media	trust	any	any	untrust	any	facebook-base, twitter-base, instagram	application-default	deny	—		2,341	🔗 📄 ⬆ ⬇ 🛑
9	Allow FTP to DMZ	trust	Admin-Subnet	any	dmz	any	ftp	application-default	allow	○		123	🔗 📄 ⬆ ⬇ 🛑
10	SSH Management	trust	Admin-Subnet	any	trust	Firewall-Mgmt	ssh	service-ssh	allow	—		890	🔗 📄 ⬆ ⬇ 🛑
11	Block Torrents	any	any	any	any	any	bittorrent	any	deny	—		567	🔗 📄 ⬆ ⬇ 🛑
12	Default Deny	any	any	any	any	any	any	any	deny	—	📄	34,521	🔗 📄 ⬆ ⬇ 🛑
13	legacy-allow-all	trust	any	any	untrust	any	any	application-default	allow	—		0	🔗 📄 ⬆ ⬇ 🛑

legacy-allow-all rule created

Part 2: Replace It With a Least-Privilege Rule Set

Step 1: Define what the branch segment actually needs

Step 2: Build the specific allow rules

11. In Policies > Security, create a new rule named allow-dns. Source Zone trust, Destination Zone untrust, Service

dns (or the specific DNS application if App-ID exposes one), Action Allow.

12. Create allow-ntp the same way, scoped to NTP.

13. Create allow-web-https, scoped to TCP 443 / the ssl or web-browsing application.
14. Create allow-banking-app, scoped to your team's agreed banking-application port.
15. Create allow-patching, scoped to TCP 443 if it isn't already fully covered by allow-web-https — discuss as a team whether these should be one rule or two, and document your reasoning either way.
16. For every rule above, enable logging (Log at Session Start and/or Log at Session End, depending on what your simulator exposes) — you'll need this for Day 2.

allow-banking-app scoped to TCP 8443

allow-patching scoped to TCP 443

Step 3: Remove the legacy rule and confirm default-deny

17. Select legacy-allow-all and disable it (don't delete it yet — you want it visible in your "before" screenshot history). If your simulator doesn't support disabling, delete it and rely on your Step 2 screenshot from Part 1 as your before-evidence instead.

18. Confirm a default-deny rule exists at the very bottom of the rule base, matching any traffic not caught by your specific allow rules above. Most PAN-OS-style rule bases include this implicitly; if yours doesn't, add an explicit rule named default-deny-all: Source any, Destination any, Action Deny, Log enabled.

#	Name	Source Zone	Source Addr	User	Dest Zone	Dest Addr	Application	Service	Action	Profile	Opt	Hits	
1	Allow DNS	trust	any	any	untrust	any	dns	application-default	allow	○		15,420	
2	Allow Web Browsing	trust	any	any	untrust	any	web-browsing, ssl	application-default	allow	○		89,234	
3	Allow Email	trust	any	any	untrust	any	smtp, imap, pop3	application-default	allow	○		5,621	
4	DMZ Web Servers	untrust	any	any	dmz	WebServer-1, WebServer-2	web-browsing, ssl	service-http, service-https	allow	○		45,678	
5	Trust to DMZ	trust	any	any	dmz	any	any	any	allow	○		12,340	
6	Allow ICMP	trust	any	any	untrust	any	ping	application-default	allow	—		3,456	
7	VPN Access	untrust	VPN-Pool	any	trust	any	any	any	allow	○		7,890	
8	Block Social Media	trust	any	any	untrust	any	facebook-base, twitter-base, instagram	application-default	deny	—		2,341	
9	Allow-FTP-to-DMZ	trust	Admin-Subnet	any	dmz	any	ftp	application-default	allow	○		123	
10	SSH Management	trust	Admin-Subnet	any	trust	Firewall-Mgmt	ssh	service-ssh	allow	—		890	
11	Block Torrents	any	any	any	any	any	bittorrent	any	deny	—		567	
12	allow-dns	trust	any	any	untrust	any	any	dns	allow	—		0	
13	allow-ntp	trust	any	any	untrust	any	any	ntp	allow	—		0	
14	allow-web-https	trust	any	any	untrust	any	any	ssl	allow	—		0	
15	allow-banking-app	trust	any	any	untrust	any	any	TCP 8443	allow	—		0	
16	allow-patching	trust	any	any	untrust	any	any	TCP 443	allow	—		0	
17	Default Deny	any	any	any	any	any	any	any	deny	—		34,521	

19. Confirm your five allow rules sit above the default-deny rule, and that legacy-allow-all (if not deleted) is disabled or moved below default-deny so it can never match.

Allow rules sit above default-deny rule and legacy-allow-all is deleted

Part 3: Enable Application-Layer Awareness (App-ID)

20. Open your allow-web-https rule from Part 2. Look for an Application field (separate from Service/Port).
21. Instead of leaving Application set to any, set it to the specific application(s) this rule should allow — for example

ssl and web-browsing.

22. Repeat this for allow-banking-app: if your simulator lets you define or select a custom application signature for

the banking app, use it. If not, note in your deliverables that this rule is currently port-based only, and explain in

one or two sentences what risk that leaves open (an attacker running a different protocol over the same port would

still match this rule).

23. Repeat for allow-dns and allow-ntp, restricting Application to dns and ntp respectively if the fields are available.

24. Save your changes and take a screenshot showing at least one rule with a specific Application set (not any).

#	Name	Source Zone	Source Addr	User	Dest Zone	Dest Addr	Application	Service	Action	Profile	Opt	Hits	
1	Allow DNS	trust	any	any	untrust	any	dns	application-default	allow	○		15,420	
2	Allow Web Browsing	trust	any	any	untrust	any	web-browsing, ssl	application-default	allow	○		89,234	
3	Allow Email	trust	any	any	untrust	any	smtp, imap, pop3	application-default	allow	○		5,621	
4	DMZ Web Servers	untrust	any	any	dmz	WebServer-1, WebServer-2	web-browsing, ssl	service-http, service-https	allow	○		45,678	
5	Trust to DMZ	trust	any	any	dmz	any	any	any	allow	○		12,340	
6	Allow ICMP	trust	any	any	untrust	any	ping	application-default	allow	—		3,456	
7	VPN Access	untrust	VPN-Pool	any	trust	any	any	any	allow	○		7,890	
8	Block Social Media	trust	any	any	untrust	any	facebook-base, twitter-base, instagram	application-default	deny	—		2,341	
9	Allow FTP to DMZ	trust	Admin-Subnet	any	dmz	any	ftp	application-default	allow	○		123	
10	SSH Management	trust	Admin-Subnet	any	trust	Firewall-Mgmt	ssh	service-ssh	allow	—		890	
11	Block Torrents	any	any	any	any	any	bittorrent	any	deny	—		567	
12	allow-dns	trust	any	any	untrust	any	dns	dns	allow	○		0	
13	allow-ntp	trust	any	any	untrust	any	ntp	ntp	allow	○		0	
14	allow-web-https	trust	any	any	untrust	any	web-browsing, ssl	ssl	allow	○		0	
15	allow-banking-app	trust	any	any	untrust	any	any	TCP 8443	allow	○		0	
16	allow-patching	trust	any	any	untrust	any	ssl	TCP 443	allow	○		0	
17	Default Deny	any	any	any	any	any	any	any	deny	—		34,521	

Note: Leaving the Application set to any for allow-banking-app because simulator does not allow you to build custom application signatures for TCP 8443

Part 4: Enable Threat Prevention and Threat Intelligence

One: Go to Objects > Security Profiles > Vulnerability Protection. There's already a profile there called Vuln-Protect-Default. Click its name. If it opens, write down what actions are set for critical and high severity. If it won't open, just write 'profile not editable in simulator' and move on. Sixty seconds, then done with that screen.

Vulnerability Profile — Vuln-Protect-Default

General

Rules

Severity-based Actions

Critical	reset-both
High	reset-both
Medium	reset-client
Low	default
Informational	default

Cancel

Two: Go back to Policies > Security. Open each of your five allow rules. Go to the Actions tab, find Profile Setting, and attach Vuln-Protect-Default. Do this on all five rules. Screenshot one of them showing the profile attached. This is the part that counts.

Security Policy Rule — allow-dns

General

Source

Destination

Application

Service/URL Category

Actions

Target

Action

Allow

Profile Setting

Profiles

Security Profile Group

Vuln-Protect-Default

Log at Session Start

☐ Enable

Log at Session End

☒ Enable

Log Forwarding

default

Schedule

None

QoS Marking

None

Disable Server Response Inspection

☐ Disable

OK

Cancel

Three: Skip the threat intelligence feed step entirely. Instead, write two sentences: what an external dynamic list does, and why a feed that silently stops updating is a security gap nobody notices. That's your deliverable for that step.

An external dynamic list allows a firewall to automatically import and enforce policies against third-party feeds of known malicious IP addresses or domains without requiring manual rule updates. If this feed silently stops updating, the firewall continues to operate on stale data, leaving the network unprepared for any malicious traffic.

Part 5, the testing table: if you don't find a policy-test tool in this simulator, don't hunt for one. Instead, for each of the seven rows, trace it by hand : walk down your rule list top to bottom and write which rule that traffic hits first. That's exactly how the firewall evaluates it anyway, and honestly it's better practice than clicking a button.

#	Traffic	Expected Result	Actual Result (First Rule Hit)
1	trust → untrust, DNS (UDP 53)	Allowed	Allowed
2	trust →NTP (UDP 123)	Allowed	Allowed
3	trust →HTTPS (TCP 443)	Allowed	Allowed
4	trust →banking app port (TCP 8443)	Allowed	Allowed (Hits Rule 15: allow-banking-app)

5	trust → unrelated port (e.g. TCP 23/Telnet)	Blocked	Blocked (Hits Rule 17: Default Deny)
6	trust → unrelated port (e.g. TCP 3389/RDP)	Blocked	Blocked (Hits Rule 17: Default Deny)

Last thing: keep a running list of every screen where a control doesn't respond. That goes in your team's report as a Tool Limitations section. You'll inherit tools in the field that don't do what the datasheet says — documenting the gap is real work, not a consolation prize."

Reflection Questions

Answer as a team, briefly, in your own words (3-5 sentences each):

38. Why does a rule like legacy-allow-all tend to survive for years in a real network even though everyone agrees it's a bad idea?

Temporary rules are often created to get a system working migration or to resolve any issues. Once the immediate problem is solved, admins are afraid that deleting the rule will break something else. Because nobody circles back to audit the firewall, the temporary fix becomes permanent.

39. What specifically can App-ID catch that a traditional port-and-protocol firewall rule would miss?

A traditional rule only checks the port number, meaning an attacker can use exploitation tools through an allowed port like TCP 443. App-ID looks inside the traffic to verify the real software being used, preventing attackers from exploiting approved ports.

40. Your default-deny rule and your specific allow rules both stop unwanted traffic. Why do you still need both, instead of relying on just one or the other?

Allow rules specifically permit the few services the network needs to function. Because it is impossible to predict and manually block every single threat on the internet, the default-deny rule acts as a safety net that automatically blocks all non-specified traffic.

Day 2

Traffic Monitoring, Threat Detection & Network Segmentation

Day 2: 9/1/26

Jason Man

Day 2: Traffic Monitoring and Threat Detection

Part 1: Confirm Logging Is Enabled

1. Open a browser and go to <https://paloalto-fw.networkershome.com>. Confirm the simulator loads and shows the PAN-OS-style management console.
2. Go to Policies > Security. Open the rule your Rule Configuration Lead built on Day 1 for the branch segment's outbound and inbound traffic.
3. Scroll to the Actions section of the rule (or the log-forwarding settings, depending on the exact layout you see). Confirm both Log at Session Start and Log at Session End are enabled. If you only see one logging option, enable that one and note in your deliverables which option your simulator version is exposed

Security Policy Rule — allow-dns

General Source Destination Application Service/URL Category **Actions** Target

Action: Allow

Profile Setting: Profiles

Security Profile Group: Vuln-Protect-Default

Log at Session Start: ☒ Enable

Log at Session End: ☒ Enable

Log Forwarding: default

Schedule: None

QoS Marking: None

Disable Server Response Inspection: ☐ Disable

OK Cancel

Log at Session Start/End both enabled for all rules configured on Day 1

4. Repeat this check for every security rule your team built on Day 1, including the default-deny rule at the bottom of the rule base. A default-deny rule with logging off is a common real-world audit finding — you want every dropped packet logged too, not just the allowed ones.

General	Source	Destination	Application	Service/URL Category	Actions	Target
Action Deny						
Profile Setting None						
Log at Session Start ☒ Enable						
Log at Session End ☒ Enable						
Log Forwarding default						
Schedule None						
QoS Marking None						
Disable Server Response Inspection ☐ Disable						

OK **Cancel**

Log at Session Start/End both enabled for Default Deny

Part 2: Confirm Threat Prevention Is Attached

5. Go to Objects > Security Profiles > Threat Prevention (sometimes labeled Vulnerability Protection or Anti- Spyware, depending on the simulator build).

6. Confirm the profile your team enabled on Day 1 exists and is set to Block (or Reset/Drop) for critical and high-severity signatures, not merely Alert.

Vulnerability Profile — Vuln-Protect-Default

General

Rules

Severity-based Actions

Critical	reset-both
High	reset-both
Medium	reset-client
Low	default
Informational	default

Cancel

Profile set to reset for Critical, High, Medium severity

7. Go back to Policies > Security and confirm this Threat Prevention profile is actually attached to your branch inbound rule under the Actions tab, in the Profile Type / Profile Setting section. A profile that exists but isn't attached to any rule protects nothing — this is worth double-checking carefully.

Security Policy Rule — allow-banking-app

General

Source

Destination

Application

Service/URL Category

Actions

Target

Action	Allow
Profile Setting	Profiles
Security Profile Group	Vuln-Protect-Default
Log at Session Start	☒ Enable
Log at Session End	☒ Enable
Log Forwarding	default
Schedule	None
QoS Marking	None
Disable Server Response Inspection	☐ Disable

OK

Cancel

Profile attached to all inbound rules

8. If your team also configured a Threat Intelligence / external dynamic list (EDL) feed on Day 1, confirm it shows a status of Active or Downloaded rather than Pending or Failed.

N/A

Part 3: Generate and Detect a Simulated Threat

N/A

Part 4: Read and Interpret the Sample Threat Log

Time	Source IP	Destination IP	Signature	Category	Severity	Action
08:14:02	10.50.2.41	198.51.100.14	TCP-SYN-Scan	Reconnaissance	medium	alert
08:14:05	10.50.2.41	198.51.100.15	TCP-SYN-Scan	Reconnaissance	medium	alert
08:14:09	10.50.2.41	198.51.100.16	TCP-SYN-Scan	Reconnaissance	medium	alert
08:14:44	10.50.2.41	198.51.100.22	TCP-SYN-Scan	Reconnaissance	medium	alert
09:02:17	203.0.113.77	10.50.3.10	EICAR-Test-File	Malware (test signature)	high	blocked
09:47:33	10.50.1.19	10.50.3.12	HTTP	Suspicious User-Agent	low	allowed
10:12:05	198.51.100.203	10.50.3.10	Generic-SQL-Injection	Web Attack	critical	blocked
11:05:51	10.50.1.44	203.0.113.5	DNS	DGA-Domain-Lookup	high	blocked
12:31:09	10.50.1.60	198.51.100.90	SSL	Expired-Cert-Endpoint	low	alert
13:18:22	198.51.100.203	10.50.3.10	Generic-SQL-Injection	Web Attack	critical	blocked
14:02:40	10.50.1.19	10.50.3.12	HTTP	Suspicious User-Agent	low	allowed
15:44:12	203.0.113.220	10.50.3.15	SMB	EternalBlue-Signature	critical	blocked
16:09:58	10.50.1.77	8.8.8.8	DNS	n/a (normal)	informational	allowed
16:55:03	198.51.100.203	10.50.3.10	Generic-SQL-Injection	Web Attack	critical	blocked
17:20:47	10.50.1.19	10.50.3.12	HTTP	Suspicious User-Agent	low	allowed

● Which log entries represent the port scan reconnaissance activity, and which source IP is running it?

This is the TCP-SYN-Scan logs between 08:14:02 and 08:14:44 with the source IP running this scan being 10.50.2.41

- Which single entry represents the most severe event in the dataset, and what specific threat signature or category triggered it?

The most severe event is the entry at 15:44:12, triggered by the SMB signature under the EternalBlue-Signature threat category.

- For the most severe entry, what action did the firewall take (allow, alert, drop, reset, block)? Is that the correct action for that severity level, or should it have been more aggressive?

The firewall blocked this entry. This is the correct action as EternalBlue can allow an attacker to compromise the internal system so blocking it completely is necessary.

- Pick any one entry with action = "allowed." Is that an appropriate allow, or does it look like something that should have been blocked? Justify your answer in one or two sentences.

The entry at 09:47:33 that repeated throughout the day for a HTTP signature and Suspicious User-Agent category was allowed. Repeated suspicious HTTP entries from an internal host could indicate malicious traffic so blocking it would be justified, especially for a banking environment that should have strict controls.

Part 5: Build Your Daily Traffic/Threat Summary

Using the full Appendix A dataset, build a one-page daily summary a SOC shift lead could read in under a minute.

Include:

- Total blocked/dropped events for the day
- Top 3 blocked threat categories, ranked by count
- Top 3 source IP addresses by event count, with a one-line note on which ones look like they warrant a follow-up investigation
- Any single event you would escalate to Tier 2 if this were a live shift, and why

Traffic & Threat Summary:

Total Blocked Events: 6 events were blocked or dropped.

Top 3 Blocked Threat Categories:

- Web Attack (3 events)
- DGA-Domain-Lookup (1 event)
- EternalBlue-Signature (1 event)

Top 3 Source IP Addresses:

- 10.50.2.41 (4 events): Internal host is conducting rapid outbound TCP-SYN reconnaissance scans, warrants investigation for a compromised internal machine.
- 198.51.100.203 (3 events): External host attempting repeated SQL injections, the firewall is successfully blocking it, so this requires no immediate internal incident response.
- 10.50.1.19 (3 events): Internal host continuously generating suspicious HTTP user-agent traffic, warrants follow-up to determine if this is a misconfigured application or malware.

Tier 2 Escalation:

Event: 11:05:51- Source IP 10.50.1.44 triggered a high-severity DGA-Domain-Lookup

Even though the firewall successfully blocked the DNS request, a Domain Generation Algorithm lookup originating from an internal IP address indicates that the endpoint (10.50.1.44) is already infected with malware actively trying to locate its C2 server. A Tier 2 analyst needs to isolate this host immediately and perform endpoint forensics.